IS07 — Logging and Monitoring Policy

[Company] IIoT Platform

Project name: [Company] Security Policies	Status: Active
Date: [Date]	Version: 1.0
Author: [Author Name]	Reviewer: [Reviewer Name]

Versions

Revision	Date	Author	Description
1.0	[Date]	[Author Name]	Initial release

Related Standards, Policies and Processes

- IS01 - [Company] Information Security Policy
- DP01 - Data Protection and Retention Policy

Definitions and Terms

Definitions and terms used in this policy follow the SANS Institute Glossary of Security Terms.

Overview

This policy defines the standards and requirements for event logging and monitoring across the [Company] IIoT Platform. It is a critical component of the information security strategy, supporting compliance with best practices, security standards and client requirements. The policy ensures that logs and metrics are systematically collected, protected, and analyzed to safeguard customer data, ensure service continuity, and detect potential security incidents.

Purpose

The primary purpose of this policy is to establish a framework for logging and monitoring activities to:

- Ensure full traceability (auditability) of operations performed on customer data and critical system resources.

- Enable the timely detection, investigation, and response to security incidents, unauthorized access attempts, and system anomalies.
- Provide continuous monitoring of system performance and availability to ensure adherence to client Service Level Agreements (SLAs).
- Collect logs and metrics to support business intelligence (BI), analysis, service optimization, and troubleshooting.
- Meet compliance obligations under applicable standards (e.g., ISO 27001, SOC 2) and other legal or contractual requirements.

Scope

All employees, contractors, consultants, temporary and other workers of [Company] working on the [Company] IIoT Platform must adhere to this policy. This policy applies to all operations maintained and run on the [Company] platform and its components.

Policy

General Logging

- All critical systems, applications and network components within the [Company] IIoT Platform must have logging enabled.
- All systems must synchronize to an approved central time source (e.g., NTP) to ensure consistent timestamps.

Customer Data Operations

All operations concerning customer data within cloud resources must be logged. These logs must capture sufficient detail to identify the user or process, the operation performed, the timestamp, the source and the resource affected.

Network Resource Logging

Logs from network resources (IoT gateways) must be securely collected and centralized. These logs must be:

- made available to the client, in accordance with contractual agreements;
- accessible for download and analysis by authorized internal systems (e.g., Access Controller, IoT Hub).

SLA Monitoring

- Continuous monitoring systems must be implemented to track key performance indicators (KPIs) and availability metrics relevant to client SLAs.

- Automated alerts must be configured to notify the responsible teams of any potential or actual SLA breaches.

Use for Business Intelligence

Logs and metrics may be used for business intelligence and analysis. Before such use, any sensitive or personal customer data must be anonymized or pseudonymized in accordance with the Data Protection and Retention Policy (DP01).

Log Protection and Retention

- All logs must be protected against unauthorized access, modification and deletion.
- Logs shall be retained for the periods defined in the Data Protection and Retention Policy (DP01) to meet business, legal and compliance requirements.

Log Review

Security and system logs shall be reviewed regularly, through automated tools and manual processes as needed, to identify anomalies, security events and operational issues.

Policy Compliance

Compliance Measurement

Compliance with this policy will be verified through:

- regular internal and external audits (e.g., as part of ISO 27001 or SOC 2 assessments, or customer assessments);
- periodic reviews of logging and monitoring configurations on critical systems;
- testing of SLA and security alerting mechanisms to ensure they are functional;
- review of all documented exceptions to ensure they are current, justified and formally approved.

Exceptions

Any exception to the policy must be approved by the Security Team in advance.

Non-Compliance

An employee or entity found to have violated this policy may be subject to disciplinary action.